



POLITIQUE DE SECURITE DES SYSTEMES D'INFORMATION



HISTORIQUE DES VERSIONS			
Version	Date	Auteur	EVOLUTION DU DOCUMENT
1.0	01/01/2024	RSSI	Création initiale.
2.0	14/01/2026	RSSI	Mise à jour majeure suite à l'analyse des risques "Vol de données & Non-conformité". Intégration des exigences NIS 2.

Table des matières

Table des matières	1
PRÉAMBULE	2
Objectifs du document	2
Gestion du document	2
PARTIE I : ÉLÉMENTS STRATÉGIQUES	3
1. PÉRIMÈTRE DE LA PSSI	3
2. ENJEUX ET ORIENTATIONS STRATÉGIQUES	4
3. ASPECTS LÉGAUX ET RÉGLEMENTAIRES	5
4. ÉCHELLE DE BESOINS ET DE GRAVITÉ	5
5. BESOINS DE SÉCURITÉ (Critères DICP)	6
6. ORIGINES DES MENACES	7
PARTIE II : RÈGLES DE SÉCURITÉ ET CONTRÔLES	11
7. GOUVERNANCE ET CONFORMITÉ	11
8. SÉCURITÉ DES RESSOURCES HUMAINES	12
9. CONTRÔLE D'ACCÈS ET IDENTITÉS	13
10. PROTECTION DE L'INFORMATION ET CRYPTOGRAPHIE	14
11. SÉCURITÉ DE L'EXPLOITATION ET DU CLOUD	15
12. RÉSILIENCE ET CONTINUITÉ D'ACTIVITÉ	16
13. SÉCURITÉ DES RELATIONS FOURNISSEURS	17
ANNEXES	18
ANNEXE A : GLOSSAIRE	18
ANNEXE B : SYNTHÈSE DU PLAN D'ACTION (PRIORITÉS)	19
ANNEXE C : CADRE DE RÉFÉRENCE ET DOCUMENTS APPLICABLES	20
ANNEXE D : SYNTHÈSE DE L'ANALYSE DE RISQUES	21

PRÉAMBULE

Objectifs du document

La présente PSSI a pour objet de définir les règles de sécurité applicables au sein de DataSecure Inc. Elle constitue le document de référence qui traduit notre stratégie de gestion des risques en mesures opérationnelles. Ses objectifs spécifiques sont :

- **Fixer le cadre réglementaire** : Définir les exigences de sécurité pour assurer la conformité au RGPD et à la directive NIS 2,
- **Protéger les actifs critiques** : Déployer les mesures techniques et organisationnelles nécessaires pour empêcher le vol de données et l'exfiltration d'informations stratégiques,
- **Responsabiliser les acteurs** : Clarifier les rôles et devoirs de chaque collaborateur, prestataire et partenaire dans la chaîne de sécurité,
- **Assurer la résilience** : Garantir la continuité des activités en cas d'incident majeur ou de cyberattaque.

Gestion du document

Ce document est une propriété confidentielle de DataSecure Inc. Il doit être revu au minimum une fois par an ou lors de tout changement significatif de l'organisation, de la réglementation ou des menaces.

Validation :

Rôle	Fonction	Date	Signature
Rédaction	RSSI	10/01/2026	<i>Lu et approuvé</i>
Vérification	DSI	14/01/2026	<i>Lu et approuvé</i>
Approbation	Directeur Général	14/01/2026	<i>Lu et approuvé</i>

PARTIE I : ÉLÉMENTS STRATÉGIQUES

1. PÉRIMÈTRE DE LA PSSI

Conformément à la méthodologie d'élaboration de la politique de sécurité, ce chapitre délimite strictement le champ d'application des règles, en distinguant les acteurs concernés (périmètre organisationnel) des actifs à protéger (périmètre technique).

1.1 Périmètre Organisationnel La présente PSSI est un document de référence qui engage la responsabilité de l'intégralité de la structure **DataSecure Inc.** Elle s'applique de manière impérative aux entités suivantes :

- **La Direction Générale :** En tant que commanditaire de la démarche SSI et responsable légale finale (notamment vis-à-vis des obligations **NIS 2** et **RGPD**), elle doit montrer l'exemple et soutenir l'application des règles,
- **Les Directions Métiers et Support :** Sont concernés la DSI (responsable de la mise en œuvre technique), la R&D (détentrices du savoir-faire), les RH (gestion des données employés) et le Service Juridique (conformité).
- **L'ensemble des collaborateurs :** Tous les utilisateurs du système d'information, quel que soit leur statut (CDI, CDD, stagiaires, intérimaires), qu'ils opèrent sur site ou en situation de télétravail/nomadisme.
- **Les Tiers et la "Supply Chain" :** L'analyse de risques ayant identifié le vecteur "Concurrent / Prestataire compromis" comme un risque de niveau **Grave (3)**, cette politique s'impose contractuellement à tous les sous-traitants, fournisseurs et partenaires ayant un accès logique ou physique à nos données (Clause de sécurité et Plan d'Assurance Sécurité obligatoires).

1.2 Périmètre Technique (Biens Supports et Valeurs Métiers) Le périmètre technique couvre les "Biens Supports" identifiés comme critiques pour supporter nos "Valeurs Métiers" lors de l'analyse EBIOS :

- **Le Patrimoine Informationnel Critique :** Il s'agit spécifiquement des **Données de Recherche & Développement (R&D)** (secrets de fabrication) et de la **Base de Données Clients** (Données à Caractère Personnel - DCP). Ces actifs sont les cibles prioritaires des scénarios de vol,
- **Les Systèmes de Traçabilité (Preuves) :** L'ensemble des journaux d'événements (logs), systèmes de journalisation (SIEM) et archives permettant de répondre aux exigences de preuve en cas d'audit réglementaire ou d'investigation post-incident,

- **Les Infrastructures de Traitement** : Tous les terminaux (postes de travail, mobiles), serveurs et équipements réseaux hébergeant ou transportant les données susmentionnées.

2. ENJEUX ET ORIENTATIONS STRATÉGIQUES

L'analyse de risques a mis en évidence que la sécurité du SI n'est pas une simple contrainte technique, mais une condition *sine qua non* de la pérennité de DataSecure Inc. Les orientations suivantes sont validées par la Direction.

2.1 Enjeu de Confidentialité et Avantage Concurrentiel (Lutte contre le Vol) La protection du secret des affaires est vitale. Le vol de nos données R&D par un **Concurrent** ou un **Cybercriminel** (espionnage industriel) constituerait une perte irréversible de notre savoir-faire et de notre avantage compétitif.

- **Orientation** : Appliquer une stratégie de défense en profondeur (Chiffrement, DLP, Moindre privilège) pour garantir que seules les personnes habilitées accèdent à ces informations sensibles.

2.2 Enjeu Juridique, Financier et de Conformité (Vital) Face au durcissement du cadre législatif européen, la non-conformité est identifiée comme un risque de gravité **Critique (G4)**.

- **Risque financier** : Le non-respect du **RGPD** expose l'entreprise à des sanctions administratives pouvant atteindre **4% du chiffre d'affaires mondial**.
- **Risque pénal** : La directive **NIS 2** engage la responsabilité pénale des dirigeants en cas de négligence avérée ou de défaut de notification d'incident.
- **Orientation** : Maintenir une veille réglementaire active et intégrer la sécurité dès la conception des projets ("Privacy by Design") pour éviter toute sanction des **Régulateurs (CNIL/ANSSI)**.

2.3 Enjeu de Réputation et de Confiance (Image) En tant que gestionnaire de données, la confiance de nos clients est notre actif le plus fragile. Une fuite de données clients ou une sanction publique par la CNIL entraînerait une rupture de contrats et une dégradation durable de notre image de marque.

- **Orientation** : Assurer une transparence totale et une capacité de réaction immédiate (Notification sous 24h/72h) pour préserver notre réputation de tiers de confiance.

3. ASPECTS LÉGAUX ET RÉGLEMENTAIRES

DataSecure Inc. évolue dans un écosystème normatif contraint. Le respect des textes suivants est obligatoire et prime sur les contraintes opérationnelles.

3.1 Règlement Général sur la Protection des Données (RGPD - UE 2016/679) Applicable à tout traitement de Données à Caractère Personnel (DCP) concernant les clients et les salariés.

- **Obligations majeures** : Tenue d'un registre des traitements, recueil du consentement, droit à l'oubli, et obligation stricte de **notifier toute violation de données à la CNIL sous 72 heures**.

3.2 Directive NIS 2 (Network and Information Security) Applicable aux entités fournissant des services essentiels ou importants.

- **Obligations majeures** : Mise en œuvre de mesures techniques (MFA, Chiffrement), audits de sécurité réguliers, sécurisation de la chaîne d'approvisionnement, et **signalement des incidents majeurs à l'ANSSI sous 24 heures**.

3.3 Normes ISO et Engagements Contractuels

- **ISO/IEC 27001** : Cadre de référence pour notre Système de Management de la Sécurité de l'Information (SMSI), visant l'amélioration continue (PDCA),
- **Contrats Clients et NDA** : Respect des clauses de confidentialité et de droit d'audit signées avec nos partenaires.

4. ÉCHELLE DE BESOINS ET DE GRAVITÉ

Afin d'objectiver l'analyse des risques (méthode EBIOS RM / ISO 27005) et de prioriser les incidents, DataSecure Inc. adopte l'échelle d'impacts suivante :

Niveau	Gravité	Définition de l'impact (Conséquences métiers, Juridiques et Financières)
G4	CRITIQUE	Survie menacée. Sanctions juridiques lourdes (ex : amende > 2% CA), engagement de la responsabilité pénale des dirigeants. Vol massif de données R&D ou Clients compromettant l'activité à long terme.

G3	GRAVE	Forte dégradation. Non-conformité majeure détectée par un audit régulateur. Fuite de données limitée nécessitant une notification publique. Perte d'image significative et perte de clients stratégiques.
G2	SIGNIFICATIF	Perturbation gérée. Incident de conformité mineur traité en interne. Dégradation temporaire de l'image sans impact médiatique large. Coût financier absorbable.
G1	MINEUR	Impact faible. Aucune conséquence notable sur la situation juridique ou l'image. Traitement au fil de l'eau.

5. BESOINS DE SÉCURITÉ (Critères DICP)

L'expression des besoins repose sur les critères de sécurité fondamentaux (Triade CIA + Preuve) appliqués aux actifs critiques ciblés par les risques de "Vol" et de "Non-conformité".

Actif Essentiel	D	I	C	P	Justification détaillée (Issue de l'Analyse de Risques)
Données R&D	2	3	4	2	Confidentialité Critique (C4) : Cible prioritaire de l'espionnage industriel (Concurrents). La divulgation de ces données détruit l'avantage concurrentiel de l'entreprise. Le besoin de protection est absolu.
Base Clients (DCP)	3	3	4	3	Confidentialité Critique (C4) : Données soumises au RGPD. Une fuite entraîne des sanctions maximales (G4) et des poursuites judiciaires. L'intégrité est aussi requise pour garantir l'exactitude des données (droit de rectification).
Journaux (Logs)	3	4	3	4	Preuve & Intégrité Critiques (I4, P4) : En cas de contrôle (CNIL/ANSSI) ou d'enquête après un vol, les logs constituent la seule preuve légale disculpatoire (Traçabilité). Ils ne doivent jamais être altérés ou supprimés par un attaquant.

Légende : D=Disponibilité, I=Intégrité, C=Confidentialité, P=Preuve/Traçabilité. Échelle de 1 (Faible) à 4 (Critique).

6. ORIGINES DES MENACES

Sur la base de la cartographie des risques (méthodologie EBIOS RM / ISO 27005), les familles de menaces suivantes ont été retenues car elles présentent une pertinence élevée pour DataSecure Inc. Elles justifient les mesures de protection déployées dans la Partie II.

6.1 Menaces Externes Intentionnelles (Cybercriminalité et Sabotage) Ces acteurs cherchent délibérément à nuire à l'entreprise pour des motifs financiers, stratégiques ou idéologiques.

- **Cybercriminels (Motivation Lucrative) :**
 - **Description :** Groupes organisés ou individus isolés motivés par l'appât du gain. Ils ne ciblent pas toujours DataSecure spécifiquement mais a des moments opportuns.
 - **Mode opératoire :** Utilisation de **Ransomwares** pour chiffrer les données et exiger une rançon, ou vol de la base clients pour revente. Les vecteurs privilégiés sont le Phishing (Hameçonnage) et l'exploitation de vulnérabilités non corrigées.
 - **Pertinence :** Élevée.
- **Concurrents (Motivation Stratégique) :**
 - **Description :** Entreprises rivales cherchant à s'approprier notre savoir-faire (Secrets de fabrication R&D) ou nos parts de marché.
 - **Mode opératoire :** Espionnage industriel ciblé. Ils peuvent tenter d'infiltrer le système d'information via un prestataire de service compromis (Attaque par la "Supply Chain") ou par le débauchage de salariés clés.
 - **Pertinence :** Élevée.
- **Activistes / Saboteurs (Motivation Idéologique) :**
 - **Description :** Groupes ou individus cherchant à nuire à l'image de marque de l'entreprise ou à bloquer sa production pour des raisons politiques, éthiques ou de vengeance.
 - **Mode opératoire :** Attaques par Déni de Service (DDoS) pour paralyser les services Cloud, défiguration du site web ou sabotage logique des données de production.
 - **Pertinence :** Moyenne.

6.2 Menaces Internes (Facteur Humain et Gouvernance) L'analyse de risques démontre que la menace ne vient pas uniquement de l'extérieur. Les défaillances internes sont des vecteurs majeurs de risque.

- **Utilisateur Négligent (Erreur Humaine) :**
 - **Description :** Collaborateurs contournant les règles de sécurité par souci de productivité ou manque de sensibilisation.
 - **Mode opératoire :** Usage du "Shadow IT" (outils non approuvés), clic sur un lien de Phishing, ou perte d'équipements non chiffrés. Cette source est un facilitateur majeur pour les attaquants externes.
 - **Pertinence :** Élevée (Facteur présent dans 80% des incidents).
- **Salarié Malveillant (Vengeance / Gain) :**
 - **Description :** Collaborateur en conflit (licenciement, frustration) ou motivé par l'argent.
 - **Mode opératoire :** Abus de droits d'accès légitimes pour exfiltrer des données sensibles (R&D, Clients) via des supports amovibles (Clé USB) ou des services de stockage personnels avant son départ.
 - **Pertinence :** Moyenne.
- **Défauts de Pilotage et d'Arbitrages Stratégiques :**
 - **Description :** Inadéquation entre les cycles de décision budgétaire et les impératifs de maintien en condition de sécurité. Ce risque identifie les failles liées à un manque de ressources ou à une absence de cadre décisionnel validé pour le SMSI.
 - **Conséquences opérationnelles :** Ces carences organisationnelles (absence de nomination d'un DPO, gel budgétaire) agissent comme un **catalyseur de menaces**. Par exemple, l'absence d'arbitrage pour des outils de protection permet la **diffusion d'un malware** sur le réseau R&D, tandis que le manque de budget pour la formation **amplifie l'efficacité des attaques de phishing**.

6.3 Menaces Réglementaires et Institutionnelles Bien que leur intention ne soit pas de nuire, ces acteurs représentent une menace financière et juridique directe en cas de défaillance de notre système de management.

- **Régulateurs (CNIL / ANSSI) :**
 - **Description :** Autorités chargées de faire respecter la loi (RGPD, Loi de Programmation Militaire, NIS 2).
 - **Mode opératoire :** Contrôles inopinés, audits sur plainte, ou enquêtes suite à une notification d'incident obligatoires.

- **Impact** : Capacité à infliger des sanctions administratives lourdes (jusqu'à 4% du chiffre d'affaires mondial pour le RGPD) et à engager la responsabilité pénale des dirigeants.
- **Pertinence** : Élevée.

6.4 LISTE DES THÉMATIQUES DE SÉCURITÉ ABORDÉES

Afin de répondre aux besoins de sécurité identifiés et de traiter les risques prioritaires pour **DataSecure Inc.**, la présente politique décline ses règles opérationnelles selon trois axes thématiques majeurs. Ces domaines permettent de traduire les objectifs stratégiques en mesures concrètes pour le personnel et les prestataires.

1. Thématiques communes (Socle d'hygiène informatique) Ces domaines constituent la base indispensable de la sécurité pour l'ensemble des actifs du système d'information :

- **Sécurité des Ressources Humaines** : Encadrement des processus d'arrivée et de départ, et sensibilisation continue des utilisateurs pour réduire le facteur d'erreur humaine estimé à 80% des incidents.
- **Contrôle d'accès et gestion des identités** : Mise en œuvre de l'authentification multi-facteurs (MFA) et d'une politique de mots de passe robuste selon les standards de l'ANSSI.
- **Sécurité de l'exploitation** : Maintien en condition de sécurité via la gestion des vulnérabilités (patch management) et le déploiement de solutions de détection de type EDR.

2. Thématiques spécifiques au risque "Vol de données" (Scénarios R1-R11) Mesures ciblées pour protéger le patrimoine informationnel critique (R&D et Clients) contre l'espionnage et l'exfiltration :

- **Protection de l'information et Cryptographie** : Chiffrement des données au repos et en transit, et déploiement d'outils de prévention des fuites de données (DLP).
- **Sécurité du Cloud** : Durcissement des configurations des espaces de stockage (Buckets S3) et surveillance automatisée via des outils de CSPM.
- **Sécurité des relations fournisseurs** : Encadrement contractuel de la "Supply Chain" par l'imposition de Plans d'Assurance Sécurité (PAS) et de clauses d'audit.

3. Thématiques spécifiques au risque "Non-conformité" (Scénarios R12-R22) Dispositifs visant à garantir le respect des obligations légales (RGPD, NIS 2) et à assurer la résilience de l'entreprise :

- **Gouvernance et Conformité** : Pilotage de la sécurité via un Comité de Direction (CoPil), nomination d'un Délégué à la Protection des Données (DPO) et maintien d'une veille réglementaire active.
- **Traçabilité et Preuve (Logs)** : Centralisation et protection de l'intégrité des journaux d'événements via un SIEM pour répondre aux exigences d'audit et de preuve légale.
- **Gestion de crise et Résilience** : Établissement de procédures de réponse aux incidents incluant les notifications obligatoires aux autorités (ANSSI/CNIL) et maintien de sauvegardes immuables.

PARTIE II : RÈGLES DE SÉCURITÉ ET CONTRÔLES

Cette partie traduit les besoins de sécurité identifiés dans l'analyse de risques en mesures opérationnelles. Chaque règle (RG) répond à un ou plusieurs scénarios de risques (R1 à R22 : voir [Annexe D](#)) et est associée à un contrôle (CT) pour en garantir l'efficacité.

7. GOUVERNANCE ET CONFORMITÉ

Risques couverts : R12 (Défaut de pilotage), R13 (Privacy by Design), R19 (Veille réglementaire).

– GOUV-01 - Pilotage et Conformité Légale

– Règles

- **RG-GOUV-01-001** - Réunion obligatoire du Comité de Pilotage SSI (CoPil). (Réf. ISO 27002 : 5.1)
- **RG-GOUV-01-002** - Validation annuelle du budget de cybersécurité par la Direction Générale. (Réf. ISO 27002 : 5.1)
- **RG-GOUV-01-003** - Nomination d'un Délégué à la Protection des Données (DPO). (Réf. ISO 27002 : 5.31)
- **RG-GOUV-01-004** - Consultation du DPO pour tout projet impliquant des données personnelles (AIPD). (Réf. ISO 27002 : 5.31)
- **RG-GOUV-01-005** - Réalisation d'une veille réglementaire mensuelle (NIS 2, RGPD, DORA). (Réf. ISO 27002 : 5.36)

– Contrôle

● **CT-RG-GOUV-01-001 – Revue documentaire manuelle**

- Vérifier la présence des procès-verbaux (PV) de réunion signée par la Direction. (Réf. ISO 27002 : 5.35)
- Fréquence : 1 fois par trimestre.
- Rapport envoyé par courriel à : Direction Générale.

- **CT-RG-GOUV-01-002 – Audit de conformité projet**

- Vérifier la présence de l'avis formel du DPO dans les dossiers de lancement de projet. (Réf. ISO 27002 : 5.35)
- Fréquence : À chaque nouveau projet.
- Rapport envoyé par courriel à : RSSI.

8. SÉCURITÉ DES RESSOURCES HUMAINES

Risques couverts : R10 (Corruption), R11 (Fraude au Président), R20 (Défaut de sensibilisation).

- **RH-01 - Sensibilisation et Cycle de vie du collaborateur**

- **Règles**

- **RG-RH-01-001** - Signature d'un accord de confidentialité (NDA) avant tout accès au SI. (Réf. ISO 27002 : 6.6)
- **RG-RH-01-002** - Révocation des accès informatiques le jour effectif du départ (Off-boarding). (Réf. ISO 27002 : 6.5)
- **RG-RH-01-003** - Restitution intégrale du matériel (PC, clés, badges) sous 24h après le départ. (Réf. ISO 27002 : 8.1)
- **RG-RH-01-004** - Formation annuelle obligatoire à la cybersécurité (Phishing, Fraude au président). (Réf. ISO 27002 : 6.3)
- **RG-RH-01-005** - Validation du module "Fondamentaux SSI" sous 30 jours pour tout nouvel arrivant. (Réf. ISO 27002 : 6.3)

- **Contrôle**

- **CT-RG-RH-01-001 – Script automatisé de corrélation**

- Croiser le fichier des sortants RH avec les comptes actifs de l'Active Directory (AD). (Réf. ISO 27002 : 5.18)
- Fréquence : 1 fois par mois.
- Rapport envoyé par courriel à : RSSI / DRH.

- **CT-RG-RH-01-002 – Simulation d'attaque automatisée**

- Envoi de faux emails de phishing pour mesurer le taux de clic et de compromission. (Réf. ISO 27002 : 6.3)
- Fréquence : 1 fois par semestre.
- Rapport envoyé par courriel à : CoPil SSI.

9. CONTRÔLE D'ACCÈS ET IDENTITÉS

Risques couverts : R1 (Phishing/VPN), R6 (Point d'eau), R8 (Secrets dans le code).

- **ACC-01 - Politique d'Authentification et Mots de passe**

- **Règles**

- **RG-ACC-01-001** - Taille minimale des mots de passe : 14 caractères. (Réf. ISO 27002 : 5.17)
- **RG-ACC-01-002** - Complexité : Alphanumérique avec caractères spéciaux. (Réf. ISO 27002 : 5.17)
- **RG-ACC-01-003** - Changement obligatoire tous les 90 jours. (Réf. ISO 27002 : 5.17)
- **RG-ACC-01-004** - Historique de conservation : Interdiction de réutilisation des 10 derniers mots de passe. (Réf. ISO 27002 : 5.17)
- **RG-ACC-01-005** - Blocage du compte au bout de 5 tentatives échouées. (Réf. ISO 27002 : 5.17)
- **RG-ACC-01-006** - Durée du blocage du compte : 4 heures. (Réf. ISO 27002 : 5.17)
- **RG-ACC-01-007** - Authentification Multi-Facteurs (MFA) obligatoire pour les accès distants et comptes privilèges. (Réf. ISO 27002 : 5.17)

- **Contrôle**

- **CT-RG-ACC-01-001 – Script automatisé d'audit AD**

- Vérifier si la politique définie dans LDAP / AD respecte les RG-ACC-01-001 à 006. (Réf. ISO 27002 : 5.17)
- Fréquence : 1 fois par semaine.
- Rapport envoyé par courriel à : Responsable Infrastructures.

- **CT-RG-ACC-01-002 – Audit technique de robustesse (type John the Ripper)**

- Vérifier la résistance des condensats (hashes) des mots de passe en base. (Réf. ISO 27002 : 8.9)
- Fréquence : 1 fois par mois.
- Rapport envoyé par courriel à : RSSI.

10. PROTECTION DE L'INFORMATION ET CRYPTOGRAPHIE

Risques couverts : R3 (Exfiltration USB), R5 (Vol physique), R7 (Shadow IT), R9 (Wi-Fi public).

- **CRY-01 - Chiffrement et Prévention des fuites (DLP)**

- **Règles**

- **RG-CRY-01-001** - Chiffrement intégral des disques durs des postes portables (Bitlocker). (Réf. ISO 27002 : 8.1)
- **RG-CRY-01-002** - Utilisation exclusive de protocoles chiffrés (TLS 1.2+, VPN IPsec) pour les flux métiers. (Réf. ISO 27002 : 8.24)
- **RG-CRY-01-003** - Interdiction de l'usage du Wi-Fi public sans tunnel VPN actif. (Réf. ISO 27002 : 8.24)
- **RG-CRY-01-004** - Blocage technique des ports USB pour les supports de stockage non approuvés. (Réf. ISO 27002 : 8.12)
- **RG-CRY-01-005** - Blocage des services de stockage Cloud personnels (Shadow IT). (Réf. ISO 27002 : 8.12)

- **Contrôle**

- **CT-RG-CRY-01-001 – Console de gestion automatisée (MDM)**

- Extraire le rapport de conformité du chiffrement sur 100% du parc de terminaux. (Réf. ISO 27002 : 8.1)
- Fréquence : 1 fois par semaine.
- Rapport envoyé par courriel à : Support IT.

- **CT-RG-CRY-01-002 – Analyse de logs Proxy/DLP**

- Détecter les tentatives de transfert vers des services interdits (WeTransfer, Dropbox). (Réf. ISO 27002 : 8.12)
- Fréquence : 1 fois par mois.
- Rapport envoyé par courriel à : RSSI.

11. SÉCURITÉ DE L'EXPLOITATION ET DU CLOUD

Risques couverts : R4 (Configuration S3), R14 (Défaut notification NIS 2), R16 (Rétention RGPD).

– EXP-01 - Durcissement et Surveillance

– Règles

- **RG-EXP-01-001** - Déploiement obligatoire d'un agent EDR sur 100% des serveurs et postes. (Réf. ISO 27002 : 8.7)
- **RG-EXP-01-002** - Application des correctifs de sécurité critiques sous 48 heures. (Réf. ISO 27002 : 8.8)
- **RG-EXP-01-003** - Interdiction des buckets Cloud (S3) en accès public par défaut. (Réf. ISO 27002 : 8.12)
- **RG-EXP-01-004** - Stockage des clés API et secrets dans un coffre-fort numérique (Key Vault). (Réf. ISO 27002 : 5.16)
- **RG-EXP-01-005** - Suppression automatique des données personnelles après 3 ans d'inactivité client. (Réf. ISO 27002 : 5.33)

– Contrôle

- **CT-RG-EXP-01-001 – Scan automatisé CSPM**

- Vérifier les mauvaises configurations des ressources Cloud (Buckets, droits IAM). (Réf. ISO 27002 : 8.12)
- Fréquence : 1 fois par jour.
- Rapport envoyé par courriel à : Cloud Manager.

- **CT-RG-EXP-01-002 – Rapport de vulnérabilités automatisé**

- Lister les systèmes dont les correctifs critiques datent de plus de 48h. (Réf. ISO 27002 : 8.8)
- Fréquence : 1 fois par semaine.
- Rapport envoyé par courriel à : Responsable Exploitation.

12. RÉSILIENCE ET CONTINUITÉ D'ACTIVITÉ

Risques couverts : R22 (Absence gestion de crise).

- **RES-01 - Sauvegarde et Gestion de Crise**

- **Règles**

- **RG-RES-01-001** - Application de la règle de sauvegarde 3-2-1 (3 copies, 2 supports, 1 hors site). (Réf. ISO 27002 : 8.13)
- **RG-RES-01-002** - Immuabilité des sauvegardes (verrouillage objet) contre les ransomwares. (Réf. ISO 27002 : 8.13)
- **RG-RES-01-003** - Tenue d'un exercice de crise annuel simulant une cyberattaque majeure. (Réf. ISO 27002 : 5.24)
- **RG-RES-01-004** - Notification des incidents majeurs à l'ANSSI sous 24h (Loi NIS2). (Réf. ISO 27002 : 6.8)

- **Contrôle**

- **CT-RG-RES-01-001 – Rapport de backup automatisé**

- Vérifier le statut (Succès/Échec) des jobs de sauvegarde quotidiens. (Réf. ISO 27002 : 8.13)
- Fréquence : Chaque matin (Quotidien).
- Rapport envoyé par courriel à : Administrateur Système.

- **CT-RG-RES-01-002 – Test de restauration technique**

- Réaliser une restauration complète d'une machine virtuelle critique en bac à sable. (Réf. ISO 27002 : 8.13)
- Fréquence : 1 fois par semestre.
- Rapport envoyé par courriel à : DSI / RSSI.

13. SÉCURITÉ DES RELATIONS FOURNISSEURS

Risques couverts : R2 (Supply Chain), R15 (Absence clauses PAS), R21 (Refus d'audit).

– FRN-01 - Maîtrise des Tiers

– Règles

- **RG-FRN-01-001** - Signature obligatoire d'un Plan d'Assurance Sécurité (PAS) par le fournisseur. (Réf. ISO 27002 : 5.19)
- **RG-FRN-01-002** - Insertion d'une clause de droit d'audit annuel dans tous les contrats critiques. (Réf. ISO 27002 : 5.22)
- **RG-FRN-01-003** - Revue annuelle de la conformité SSI des prestataires ayant accès aux données R&D. (Réf. ISO 27002 : 5.22)

– Contrôle

- **CT-RG-FRN-01-001 – Revue contractuelle manuelle**

- Vérifier la présence des clauses de sécurité et PAS dans les nouveaux contrats signés. (Réf. ISO 27002 : 5.19)
- Fréquence : 1 fois par an.
- Rapport envoyé par courriel à : Direction Juridique / Achats.

ANNEXES

ANNEXE A : GLOSSAIRE

Ce glossaire définit les termes techniques et acronymes utilisés dans le présent document afin d'en faciliter la lecture par l'ensemble du personnel (non-technique) et la Direction.

Terme / Acronyme	Définition
ANSSI	Agence Nationale de la Sécurité des Systèmes d'Information. Autorité française chargée de la cyberdéfense et de la régulation (NIS 2).
CNIL	Commission Nationale de l'Informatique et des Libertés. Régulateur français veillant à la protection des données personnelles (application du RGPD).
DICP	Critères de sécurité fondamentaux : Disponibilité, Intégrité, Confidentialité, Preuve (ou Traçabilité). Utilisés pour classer les données.
DLP	<i>Data Loss Prevention</i> (Prévention de la fuite de données). Solution technique permettant de détecter et bloquer l'exfiltration de données sensibles (R&D, Clients) vers l'extérieur.
DPO	<i>Data Protection Officer</i> (Délégué à la Protection des Données). Responsable chargé de veiller à la conformité de l'organisme vis-à-vis du RGPD.
EBIOS RM	Méthode d'analyse de risques développée par l'ANSSI, utilisée pour élaborer cette PSSI (Approche par scénarios).
EDR	<i>Endpoint Detection and Response</i> . Outil de surveillance installé sur les postes de travail pour détecter et bloquer les comportements malveillants (Ransomware, Spyware).
Ingénierie Sociale	Technique de manipulation psychologique (ex: Phishing) visant à tromper un utilisateur pour qu'il divulgue des informations confidentielles ou réalise une action dangereuse.
MFA	<i>Multi-Factor Authentication</i> (Authentification Multi-Facteurs). Mécanisme de sécurité exigeant deux preuves d'identité (ex: mot de passe + code téléphone) pour se connecter, bloquant le vol d'identifiants.
NIS 2	Directive européenne sur la sécurité des réseaux et des systèmes d'information, imposant des obligations de sécurité et de notification aux entités essentielles.
Phishing	(Hameçonnage). Attaque par email visant à voler des identifiants ou à distribuer des malwares. Identifié comme risque majeur (V3) pour DataSecure.

RGPD	Règlement Général sur la Protection des Données. Texte européen encadrant le traitement des données personnelles et prévoyant de lourdes sanctions financières.
Shadow IT	Utilisation de logiciels ou services (Cloud, SaaS) non approuvés par la DSI, créant des risques de fuite de données et de non-conformité.
SIEM	<i>Security Information and Event Management</i> . Système de gestion des événements de sécurité permettant de centraliser les logs (journaux) pour assurer la traçabilité et la preuve.

ANNEXE B : SYNTHÈSE DU PLAN D'ACTION (PRIORITÉS)

Ce plan d'action découle de l'analyse des risques "Vol de Données & Non-Conformité". Il classe les mesures de la PSSI par ordre de priorité pour le déploiement.

Légende des priorités :

- **P0 (Immédiat)** : Risque Critique (G4). Menace la survie ou expose à des sanctions pénales/administratives immédiates.
- **P1 (Court terme - 3 mois)** : Risque Grave (G3). Conformité majeure ou risque de vol élevé.
- **P2 (Moyen terme - 6 à 12 mois)** : Risque Significatif (Amélioration continue et culture).

Priorité	Mesure PSSI	Risque couvert (Analyse)	Responsable
P0	Déploiement du MFA sur tous les accès distants (VPN) et comptes Admin.	Vol d'identifiants (Cybercriminel) - Réduction de V3 à V1.	DSI
P0	Procédure de notification des incidents (24h/72h) et astreinte.	Sanctions Non-conformité NIS2 et RGPD (Gravité 4),.	RSSI / Juridique
P0	Chiffrement des bases de données Clients et des PC portables.	Vol de données physiques ou logiques (Confidentialité).	DSI
P1	Mise en place solution DLP (Data Loss Prevention) et blocage USB.	Exfiltration par salarié malveillant ou négligent (Interne).	DSI / RSSI
P1	Nomination du DPO et réalisation d'un audit de conformité à blanc.	Gouvernance défaillante et risque de sanctions CNIL.	Direction
P1	Centralisation des Logs (SIEM) et protection de l'intégrité.	Absence de preuve en cas d'enquête ou contrôle (Preuve).	DSI

P2	Campagnes de simulation de Phishing et formation RGPD.	Erreur humaine et Ingénierie sociale (Vraisemblable).	RH / RSSI
P2	Audit des contrats fournisseurs (PAS - Plan Assurance Sécurité).	Vol via la Supply Chain (Concurrent/Prestataire).	Juridique / Achats

ANNEXE C : CADRE DE RÉFÉRENCE ET DOCUMENTS APPLICABLES

La présente PSSI s'inscrit dans un cadre légal et normatif strict. Elle doit être lue en cohérence avec les documents suivants.

1. Référentiels Internes (Documents DataSecure Inc.)

- **Analyse de Risques (Vol & Conformité)** : Document identifiant les scénarios de menaces (Concurrents, Cybercriminels, Régulateurs) ayant justifié les règles actuelles.
- **Charte informatique** : Règles d'usage des moyens informatiques et sanctions (annexée au règlement intérieur).
- **Registre des traitements (RGPD)** : Cartographie des données personnelles traitées par l'entreprise.

2. Normes et Standards Internationaux

- **ISO/IEC 27001 :2022** : Sécurité de l'information, cybersécurité et protection de la vie privée Systèmes de management de la sécurité de l'information Exigences.
- **ISO/IEC 27002 :2022** : Code de bonnes pratiques pour la sécurité de l'information (Base des mesures de la Partie II).
- **ISO/IEC 27005 :2022** : Gestion des risques liés à la sécurité de l'information (Méthodologie utilisée pour l'analyse).

3. Cadre Légal et Réglementaire

- **RGPD (UE 2016/679)** : Règlement Général sur la Protection des Données, imposant la protection des données clients et salariés.
- **Directive NIS 2 (UE 2022/2555)** : Mesures destinées à assurer un niveau élevé commun de cybersécurité (Obligations de signalement et de gouvernance).
- **Loi Informatique et Libertés** : Loi n° 78-17 du 6 janvier 1978 modifiée.

4. Guides de bonnes pratiques (ANSSI)

- Guide d'hygiène informatique (ANSSI) : Règles essentielles pour la sécurisation du SI.
- Recommandations relatives à l'authentification multifacteur et aux mots de passe (ANSSI).
- Maîtriser les risques de l'infogérance (ANSSI) : Pour la gestion de la sécurité des fournisseurs.

ANNEXE D : SYNTHÈSE DE L'ANALYSE DE RISQUES

Cette annexe détaille les scénarios de menaces ayant conduit à l'élaboration des règles de la présente PSSI. Elle démontre l'efficacité de la stratégie de sécurité par la réduction du niveau de risque (Passage du risque *Initial* au risque *Résiduel*).

VOL DE DONNÉES (Confidentialité)

Code	Source	Menace / Scénario Stratégique	Gravité Initiale
R1	Cybercriminel	Phishing (Hameçonnage) : Vol d'identifiants par email piégé pour accéder au réseau interne via le VPN.	4 (Critique)
R2	Concurrent	Supply Chain : Intrusion indirecte en compromettant un fournisseur informatique disposant d'accès de maintenance.	3 (Grave)
R3	Salarié	Exfiltration locale (USB) : Copie de fichiers sensibles sur disque dur externe avant de quitter l'entreprise.	3 (Grave)
R4	Admin Cloud	Fuite S3 (Misconfiguration) : Configuration par défaut laissant un espace de stockage Cloud public sur Internet.	4 (Critique)
R5	Voleur	Vol Physique : Vol d'un ordinateur portable contenant des données R&D non chiffrées dans un lieu public.	3 (Grave)
R6	Cybercriminel	Attaque "Point d'eau" : Piégeage d'un site web légitime fréquenté par les employés pour infecter leur poste.	3 (Grave)
R7	Utilisateur	Shadow IT : Envoi de documents confidentiels sur une boîte mail perso ou Google Drive non sécurisé.	3 (Grave)
R8	Cybercriminel	Compromission de Code : Découverte de clés d'API ou de mots de passe stockés en clair dans les scripts (GitHub).	4 (Critique)
R9	Cybercriminel	Man-in-the-Middle (Wi-Fi) : Interception des communications d'un salarié connecté au Wi-Fi public (Gare/Hôtel).	3 (Grave)
R10	Concurrent	Corruption de personnel : Soudoyage d'un ingénieur R&D pour qu'il transmette les secrets de fabrication.	4 (Critique)

R11	Cybercriminel	Fraude au Président : Usurpation de l'identité du DG pour demander l'envoi urgent du fichier client.	3 (Grave)
------------	----------------------	---	------------------

Matrices de Synthèse (Avant / Après PSSI)

Légende :

- **(Init)** = Risque Initial (Sans protection). Zone Rouge/Orange = Inacceptable.
- **(Res)** = Risque Résiduel (Avec PSSI). Zone Verte/Jaune = Acceptable ou Sous Contrôle.

GRAVITE

		R4, R8, R10(init)	R1(init)
	R3, R5, R7(init)	R2, R6, R9, R11(init)	
	R2, R4, R8, R10(Res)		
R1, R3, R5, R6, R7, R9, R11(Res)			

VRAISSEMBLANCE

NON-CONFORMITÉ

Code	Source	Menace / Scénario de Défaillance	Gravité Initiale
R12	Gouvernance	Absence de Gouvernance : Le Comité de Pilotage SSI ne se réunit pas, le budget sécurité est gelé. L'entreprise est en défaut de "due diligence" (devoir de vigilance).	4 (Critique),
R13	DSI / Projet	Non-respect du Privacy by Design : Lancement d'une nouvelle application traitant des données clients sans consultation préalable du DPO ni analyse d'impact (AIPD).	4 (Critique),
R14	Opérationnel	Défaut de Notification (NIS 2) : Un incident survient, mais l'entreprise échoue à le notifier à l'ANSSI dans le délai légal de 24h par manque de procédure.	3 (Grave),
R15	RH / Juridique	Absence de Clauses (Supply Chain) : Les contrats avec les prestataires ne contiennent pas les clauses de sécurité (PAS) ni d'audit obligatoires (Défaut de surveillance des tiers).	3 (Grave),
R16	DSI / Admin	Conservation Illimitée (Purge) : Les données d'anciens clients (> 3 ans) ou d'anciens salariés ne sont jamais purgées des bases de données (Violation RGPD art. 5).	4 (Critique),
R17	Utilisateur	Shadow IT (Non-Maîtrise) : Utilisation massive d'outils Cloud US non conformes (ex: Google Drive perso) transférant des données hors UE sans garanties (Schrems II).	3 (Grave),
R18	DSI	Absence de Traçabilité (Logs) : En cas de contrôle CNIL ou d'enquête judiciaire, l'entreprise est incapable de fournir les journaux de connexion (Preuve légale inexistante).	3 (Grave),
R19	Juridique	Défaut de Veille : La PSSI n'est pas mise à jour selon les nouvelles lois (ex: DORA, Cyber Resilience Act), rendant l'entreprise obsolète et sanctionnable.	2 (Signif.),
R20	RH	Défaut de Sensibilisation : Les employés ne sont pas formés au RGPD/Sécurité, ce qui constitue une violation de l'obligation de "mesures organisationnelles" (Art. 32 RGPD).	3 (Grave),
R21	Prestataire	Refus d'Audit : Un fournisseur critique refuse de se soumettre à un audit de sécurité ou de fournir ses certifications, mettant DataSecure en défaut vis-à-vis de ses propres clients.	2 (Signif.)

R22	Direction	Absence de Gestion de Crise : Aucune procédure formelle n'existe pour gérer la communication publique en cas de crise, aggravant le risque d'image et les sanctions.	3 (Grave),
------------	------------------	---	-------------------

Matrices de Synthèse (Avant / Après PSSI)

Légende :

- **(Init)** = Risque Initial (Sans protection). Zone Rouge/Orange = Inacceptable.
- **(Res)** = Risque Résiduel (Avec PSSI). Zone Verte/Jaune = Acceptable ou Sous Contrôle.

GRAVITE

		<i>R12, R16(init)</i>	<i>R13(init)</i>
	<i>R18 (init)</i>	<i>R14, R15, R17, R20(init)</i>	
	<i>R19, R21(init)</i>	<i>R13, R14, R16(Res)</i>	
	<i>R12, R15, R17, R18, R19, R20, R21, R22(Res)</i>		

VRAISSEMBLANCE